

SOAR'a GİRİŞ

[Kaynak](#)

İÇERİK

1. Geleneksel SOC (Security Operations Center) Mimarisi ve Operasyonel Zorluklar
2. SOAR (Security Orchestration, Automation, and Response) Mimarisi ve Operasyonel Çözümler
3. SOAR Playbook'ları Oluşturma (Building SOAR Playbooks)

Geleneksel SOC (Security Operations Center) Mimarisi ve Operasyonel Zorluklar

Kurumların dijital varlıklarını izlemek, korumak ve siber tehditlere karşı merkezi bir savunma hattı oluşturmak amacıyla kurdukları **SOC (Security Operations Center - Güvenlik Operasyon Merkezi)**, modern siber güvenliğin kalbidir. Zaman içinde teknolojik evrim geçirerek her jenerasyonda yeni araçlar ve katmanlar entegre edilen SOC birimlerinin asıl amacı; insan, süreç ve teknoloji (People, Process, Technology) üçgenini doğru yapılandırarak ağ üzerindeki olaylara (incident) karşı sürekli izleme (continuous monitoring) ve analiz yeteneği kazanmaktır.

SOC'un Temel Yetenekleri (Core Capabilities)

Geleneksel bir SOC'un siber olaylara müdahale döngüsünde (Incident Response Lifecycle) sahip olması gereken kritik yetenekler teknik bağlamda aşağıda detaylandırılmıştır:

1. İzleme ve Tespit (Monitoring and Detection) Ağ ortamındaki şüpheli aktivitelerin sürekli olarak taranması ve bayraklanması (flagging) işlemidir. Bu sayede gelişmekte olan tehditler erken aşamada (early stage) fark edilip engellenebilir. Bu süreç genellikle **SIEM (Security Information and Event Management - Ağdaki çeşitli sistem, sunucu ve güvenlik cihazlarından gelen ham logları toplayıp, normalleştirerek [normalization] kurallar çerçevesinde korelasyon [correlation] kuran ve alarm üreten merkezi sistem)** üzerinden yürütülür.

DİKKAT: Kritik bir iş istasyonunda art arda yaşanan başarısız giriş denemeleri veya sistemde daha önce hiç görülmemiş, coğrafi olarak anomali barındıran bir lokasyondan (Impossible Travel) yapılan başarılı bir oturum açma işlemi, SIEM üzerinde bir kuralı tetikleyerek analistin önüne düşmelidir.

```
{  
  "EventID": 4625,  
  "LogonType": 3,  
}
```

```
"IpAddress": "198.51.100.45",  
"TargetUserName": "admin",  
"FailureReason": "%%2313",  
"Status": "0xC000006D"  
}
```

Yukarıdaki ham log çıktısı, bir Windows sistemden SIEM'e düşen başarısız bir ağ oturum açma (Logon Type 3) girişimidir. EventID 4625 başarısız giriş anlamına gelirken, 0xC000006D durum kodu geçersiz bir kimlik bilgisi (bad password) kullanıldığını teknik düzeyde kanıtlar. Bu logun kısa sürede yüzlerce kez tekrarlanması, SIEM tarafında bir Brute-Force (Kaba Kuvvet) alarmı oluşturur.

2. Kurtarma ve İyileştirme (Recovery and Remediation) Bir siber tehdit doğrulandığında, SOC ekibi "First Responder (İlk Müdahale Ekibi)" olarak devreye girer. Enfekte olmuş (zararlı yazılım bulaşmış) uç noktaların (endpoints) ağdan izole edilmesi, zararlı süreçlerin (malicious processes) durdurulması ve sistemin temizlenmesi bu aşamada gerçekleşir. Bu operasyonlar esnasında **EDR (Endpoint Detection and Response - Uç nokta cihazlarında dosya ve bellek aktivitelerini derinlemesine izleyen, anormallikleri tespit edip cihazı ağdan izole edebilen güvenlik çözümü)**, **Firewall (Güvenlik Duvarı)** ve **IAM (Identity and Access Management - Kimlik ve erişim yönetimi)** gibi sistemler aktif olarak kullanılır.

```
iptables -A INPUT -s 198.51.100.45 -j DROP
```

Neden bu komutu kullanıyoruz? Tespit aşamasında yakaladığımız Brute-Force saldırganının IP adresini (198.51.100.45) Linux tabanlı bir ağ geçidinde (veya Firewall'da) engellemek için. -A INPUT parametresi gelen trafiğe kural ekler, -s kaynak IP'yi belirtir ve -j DROP parametresi bu IP'den gelen tüm paketleri sessizce düşürür. Bu, olay müdahalesinin "Containment (Karantina/Sınırlandırma)" adımının teknik bir uygulamasıdır.

3. Tehdit İstihbaratı (Threat Intelligence / CTI) Ağ ortamının güncel tehditlere karşı korunması, dış dünyadan sağlanan sürekli bir veri akışına bağlıdır. SOC ekipleri; zararlı IP adresleri, dosya hash değerleri (MD5, SHA256), zararlı domainler (C2 sunucuları) ve diğer **IoC (Indicator of Compromise - Uzlaşma Göstergeleri; bir sistemin ele geçirildiğine dair adli delil veya dijital izler)** verilerini beslemeler (feeds) aracılığıyla alır. Bu istihbarat, proaktif olarak Firewall veya DNS filtrelerine kural olarak eklenir.

4. İletişim ve Koordinasyon (Communication) SOC ekipleri sadece teknik olarak izleme ve engelleme yapmaz. Bulunan bir zafiyetin veya eksik bir yamanın (patch) kapatılması için IT veya Sistem Yönetim ekipleriyle entegre çalışır. Örneğin, acil bir zafiyet için IT ekibine bilet (ticket) açılması ve bu biletin çözümünün takip edilmesi SOC'un operasyonel bütünlüğünü sağlar.

Geleneksel SOC Operasyonlarında Karşılaşılan Kritik Zorluklar

Geleneksel bir SOC'un yukarıdaki işlemleri yürütürken karşılaştığı darboğazlar, kurumun siber güvenlik duruşunu (security posture) doğrudan zayıflatan unsurlardır:

1. Alarm Yorgunluğu (Alert Fatigue) Çok sayıda güvenlik cihazının (IDS/IPS, WAF, EDR, SIEM) aynı anda çalışması, devasa bir alarm gürültüsü yaratır. Bu alarmların büyük bir kısmı **False Positive (Yanlış Pozitif - Gerçekte bir tehdit olmadığı halde sistemin tehdit olarak algılayıp alarm üretmesi)** durumlarıdır. Analistin günde binlerce niteliksiz veya eksik veri barındıran alarmı incelemek zorunda kalması, gerçek ve kritik bir güvenlik ihlalini (True Positive) gözden kaçırmasına ("boy who cried wolf" sendromu) neden olur.

2. Bağlantısız Araçlar (Disconnected Tools / Silo Problemi) Güvenlik araçlarının API veya platform düzeyinde entegre (integration) edilmeden konumlandırılması. Analist, bir tehdidi incelerken Endpoint loglarına bakmak için ayrı bir konsola, Firewall kurallarına bakmak için bambaşka bir konsola geçmek zorunda kalır. Bu durum, analizin akışını bozar ve araç sayısının (tool sprawl) altında ezilmeye yol açar.

3. Manuel Süreçler ve 'Tribal Knowledge' SOC içindeki soruşturma (investigation) ve müdahale prosedürlerinin dokümente edilmemiş olması (SOP - Standard Operating Procedures veya Playbook eksikliği) en büyük zaatlardan biridir. Süreçlerin sadece kıdemli analistlerin kişisel tecrübelerine (Tribal Knowledge - Kabile Bilgisi/Kulaktan kulağa aktarılan bilgi) dayanması, bu kişiler işten ayrıldığında operasyonun çökmesine neden olur. Dokümente edilmemiş manuel süreçler, bir olaya müdahale süresini (MTTR - Mean Time to Respond) dramatik şekilde artırır.

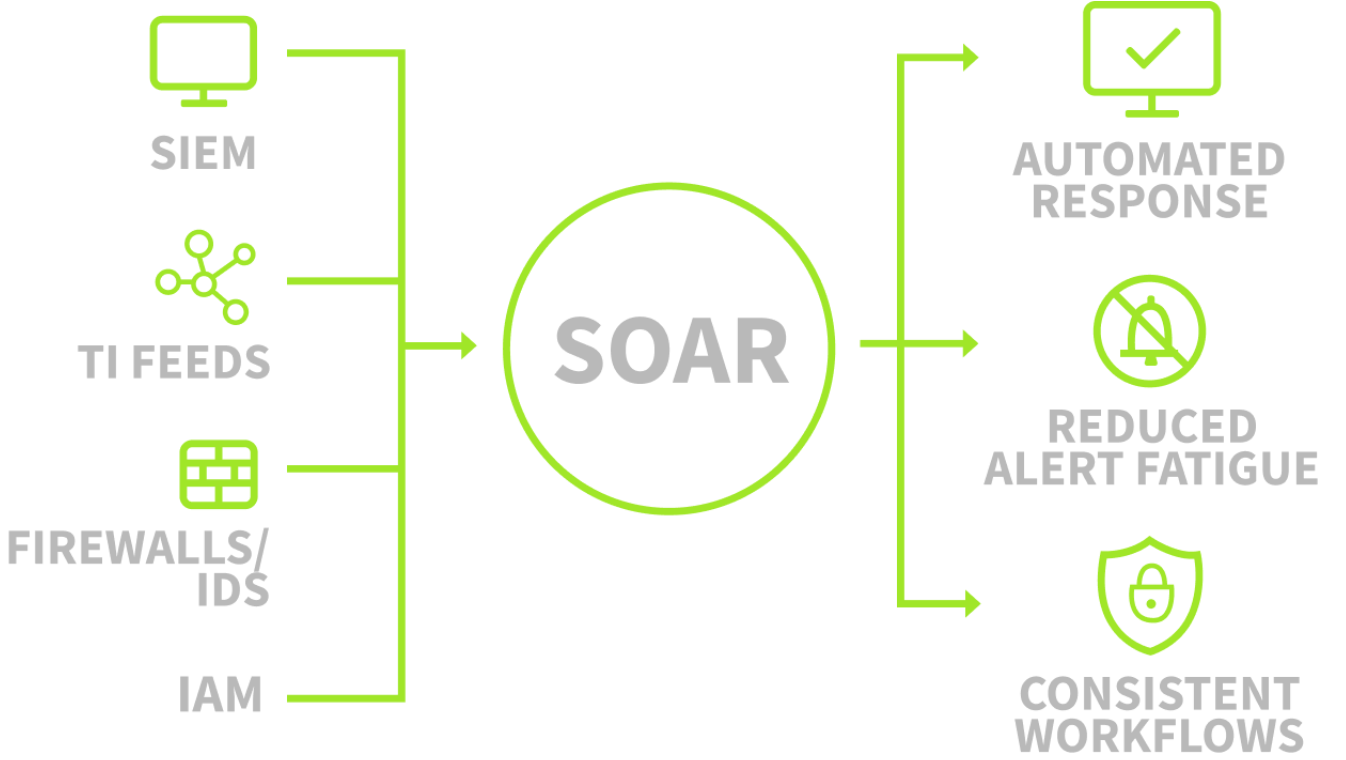
4. Yetenek Açığı (Talent Shortage) Siber tehditlerin karmaşıklığı her geçen gün artarken, bu tehditleri analiz edecek nitelikli personel (Tier 2/Tier 3 Analistler, Incident Responder'lar) bulmak giderek zorlaşmaktadır. Hem alarm yükü hem de süreçlerdeki manuel iş yükü birleştiğinde (burnout etkisi), personelin verimliliği düşer. Bu açığı fırsat bilen Gelişmiş Kalıcı Tehditler (APT - Advanced Persistent Threats), kurum ağında yatayda ilerlemek (Lateral Movement) için ihtiyaç duydukları zamana sahip olurlar.

ÖNEMLİ: Geleneksel SOC'ların içinden çıkamadığı bu "manuel iş yükü, entegre olmayan araçlar ve alarm yorgunluğu" üçgeni, süreçlerin merkezi bir platform üzerinden makine hızında otomatikleştirilmesini zorunlu kılmıştır. Modern güvenlik mimarisinde bu zorlukları aşmak ve analiste sadece kritik analitik düşünme aşamasını bırakmak için **SOAR (Security Orchestration, Automation, and Response)** teknolojileri geliştirilmiştir.

SOAR (Security Orchestration, Automation, and Response) Mimarisi ve Operasyonel Çözümler

Geleneksel SOC (Security Operations Center) mimarisinde analistlerin karşılaştığı en büyük darboğazlardan biri olan "Bağlantısız Araçlar" (Disconnected Tools) ve "Alarm Yorgunluğu" (Alert Fatigue) problemlerini çözmek için tasarlanmış nihai teknoloji **SOAR (Security Orchestration, Automation, and Response)** platformlarıdır.

SOAR; bir SOC ortamında kullanılan SIEM, EDR, Firewall, IAM gibi tüm bağımsız güvenlik bileşenlerini tek bir çatı altında birleştiren (unify), bu sistemler arasında veri akışını sağlayan ve vaka yönetimi (case management) ile biletleme (ticketing) sistemlerini entegre ederek analistlere yapılandırılmış bir olay müdahale (Incident Response) arayüzü sunan merkezi sinir sistemidir.



SOAR platformunun analitik gücü ve olay müdahale sürelerini (MTTR - Mean Time to Respond) dramatik ölçüde düşürme yeteneği, aşağıdaki üç temel kavrama (Orchestration, Automation, Response) dayanır:

1. Orchestration (Orkestrasyon)

Orkestrasyon, farklı üreticilere ait (multi-vendor) bağımsız güvenlik araçlarının SOAR arayüzü içinde birbirleriyle koordineli çalışabilmesi için entegre edilmesidir. Geleneksel bir SOC'ta analist, bir **VPN Brute-Force (Kaba Kuvvet)** alarmını incelerken şu manuel adımları izlemek zorundadır:

1. Kullanıcının hedef IP adresinden daha önce başarılı bir giriş yapıp yapmadığını teyit etmek için **SIEM** loglarını sorgulamak.
2. Hedef IP'nin itibarını (reputation) ve zararlı olup olmadığını doğrulamak için **Threat Intelligence (TI - Tehdit İstihbaratı)** platformlarını kontrol etmek.
3. Eğer saldırgan başarılı bir oturum açmışsa, hesabı devre dışı bırakmak için **IAM (Identity and Access Management - Kimlik ve Erişim Yönetimi)** konsoluna geçmek.
4. Olayı kayıt altına almak ve BT ekiplerini bilgilendirmek için bir **Ticketing (Biletleme)** sisteminde manuel kayıt oluşturmak.

Bu konsollar arası geçiş süreci operasyonu yavaşlatır. Orkestrasyon, bu araçları API'ler aracılığıyla birbirine bağlar ve olayların nasıl inceleneceğini belirleyen **Playbook (Olaylara**

müdahale adımlarını ve karar ağaçlarını içeren önceden tanımlanmış mantıksal iş akışları) yapılarını kullanır.

Aşağıda, bir SOAR platformunun arka planda bir VPN Brute-Force alarmını işlemek için kullandığı örnek bir Playbook mantığının basitleştirilmiş YAML dışı aktarımı yer almaktadır:

```
name: VPN_Brute_Force_Investigation_Playbook
trigger:
  source: SIEM_Alert
  condition: "rule.name == 'VPN_Multiple_Failed_Logins'"
steps:
  - action: query_siem_historical_logins
    target_user: "{{ alert.username }}"
    target_ip: "{{ alert.src_ip }}"
    timeframe: "last_30_days"

  - action: check_threat_intel_reputation
    plugin: "VirusTotal_API"
    target_ip: "{{ alert.src_ip }}"

  - decision_tree:
      if: "threat_intel.score > 70 AND siem_historical.match == False"
      then: escalate_to_containment
      else: close_alert_as_false_positive
```

Yukarıdaki Playbook konfigürasyonunda; SOAR'ın SIEM'den gelen bir alarmı *trigger* (tetikleyici) olarak aldığı, ardından hedeflenen IP adresinin son 30 günlük giriş geçmişini ve VirusTotal gibi bir TI platformu üzerinden zararlı olup olmadığını sorguladığı görülmektedir. Elde edilen verilere göre (*decision_tree*), eğer IP zararlıysa ve kullanıcının geçmişinde bu IP yoksa olay "Containment" (Karantina/Sınırlandırma) aşamasına taşınır. Aksi halde alarm yanlış pozitif (False Positive) olarak kapatılır.

2. Automation (Otomasyon)

Orkestrasyon, araçların nasıl entegre olacağını ve hangi adımların atılacağını (Playbook) belirlerken; Otomasyon, bu adımların insan müdahalesi (manuel tıklamalar) olmadan sistem tarafından saniyeler içinde icra edilmesidir.

Bir SOC analistinin manuel olarak logları okuması, IP adresini kopyalayıp istihbarat platformuna yapıştırması dakikalar alırken, SOAR otomasyonu sayesinde bu işlemler şu şekilde gerçekleşir:

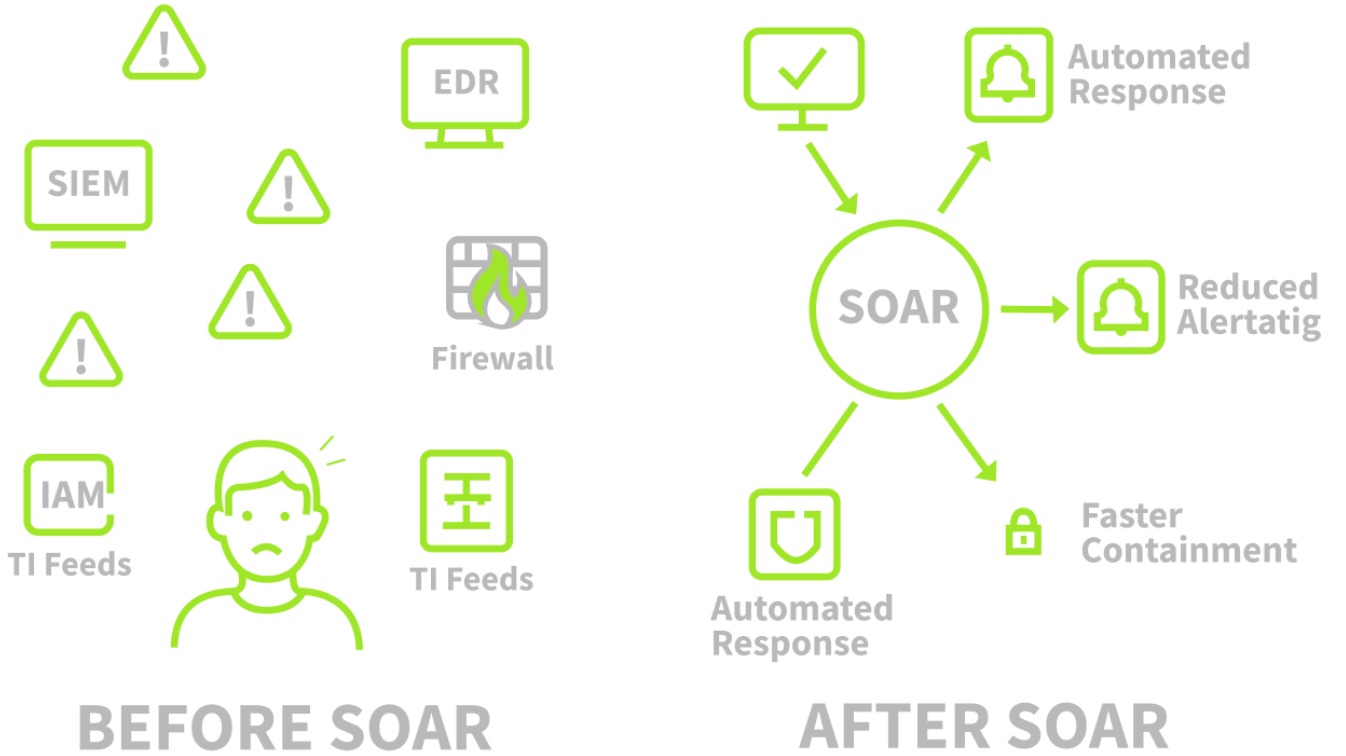
1. SOAR, alarmı SIEM'den alır almaz **otomatik olarak** kullanıcının geçmiş loglarını çeker.
2. IP'nin istihbarat verisini TI platformlarından **otomatik olarak** doğrular.
3. IP adresi zararlı olarak sınıflandırılmışsa (malicious), IAM üzerinden kullanıcının hesabını **otomatik olarak** kilitler (disable).

4. Tüm adli delilleri ve elde edilen bulguları toplayarak biletleme sisteminde detaylı bir kayıt açar.

ÖNEMLİ: Otomasyonun SOC ekiplerine sağladığı en büyük avantaj, analistlerin yüzlerce rutin alarmı incelemek zorunda kalmadan (Alert Fatigue yaşamadan) tükenmişlik (burnout) sendromundan korunmasını sağlamasıdır. Analist, sadece SOAR'ın otomatik olarak toplayıp önüne getirdiği zenginleştirilmiş (enriched) veriyi okuyarak nihai kararı verir.

3. Response (Müdahale)

Müdahale aşaması, otomasyonun mantıksal sonucudur. SOAR, sadece veri toplamakla kalmaz, aynı zamanda birleştirilmiş tek bir arayüzden dış sistemlere aksiyon komutları gönderir. VPN Brute-Force örneğinde; zararlı IP adresinin şirket Firewall'unda engellenmesi (block), Active Directory veya IAM üzerinde kullanıcının parolasının sıfırlanması veya hesabın askıya alınması SOAR'ın "Response" yeteneğidir. Tüm bu karantina işlemleri, Playbook içindeki kurallara göre tam otomatik veya analistin tek bir onay tıklamasına (Semi-Automated) bağlı olarak gerçekleştirilebilir.



Analitik Bir Çıkarım: SOC Analistlerine Hala İhtiyaç Var mı?

Sektörde sıkça sorulan "SOAR, analistlerin işini elinden mi alacak?" sorusunun teknik ve bağlamsal cevabı kesin bir "Hayır"dır.

SOAR platformları tekrarlayan (repetitive), belirli kurallara dayanan ve mantıksal sınırları çizilmiş işlemleri otomatize etmekte kusursuzdur. Ancak, karmaşık siber saldırıların (Örn: APT gruplarının yanal hareketleri, sıfırıncı gün [Zero-Day] zafiyetlerinin istismarı) analizi derin bir insan zekası gerektirir.

DİKKAT: SOAR, kurumsal iş mantığını (business context) anlayamaz. Örneğin, gece saat 03:00'te veritabanından gigabaytlarca veri çeken bir işlem SOAR için bir "Data Exfiltration (Veri Sızıntısı)" alarmı olabilir. Ancak bir SOC analisti, bu işlemin o gece yapılması planlanan meşru bir sistem yedekleme (backup) prosedürü olduğunu kurum içi iletişimi ve iş bağlamını bilerek ayırt edebilir (Judgment Call).

Ayrıca, SOAR'ın belkemiği olan **Playbook'ları yazan, güncelleyen ve siber tehdit manzarasına (threat landscape) göre optimize eden kişiler bizzat SOC analistleri ve mühendisleridir**. Sonuç olarak SOAR; analistlerin yerini almak için değil, onları "log kopyala-yapıştır" hamallığından kurtarıp, zamanlarını gerçek ve kritik tehdit avcılığına (Threat Hunting) ayırmalarını sağlamak için tasarlanmış bir güç çarpanıdır (force multiplier).

SOAR Playbook'ları Oluşturma (Building SOAR Playbooks)

Önceki aşamalarda SOAR (Security Orchestration, Automation, and Response) teknolojisinin, parçalı güvenlik araçlarını nasıl tek bir merkezde birleştirdiğini incelemiştik. Bu aşamada, SOAR'ın beyni olan ve belirli bir soruşturma (investigation) sırasında SOAR aracına hangi eylemleri gerçekleştireceğini söyleyen önceden tanımlanmış iş akışları olan **Playbook** mantığını derinlemesine analiz edeceğiz.

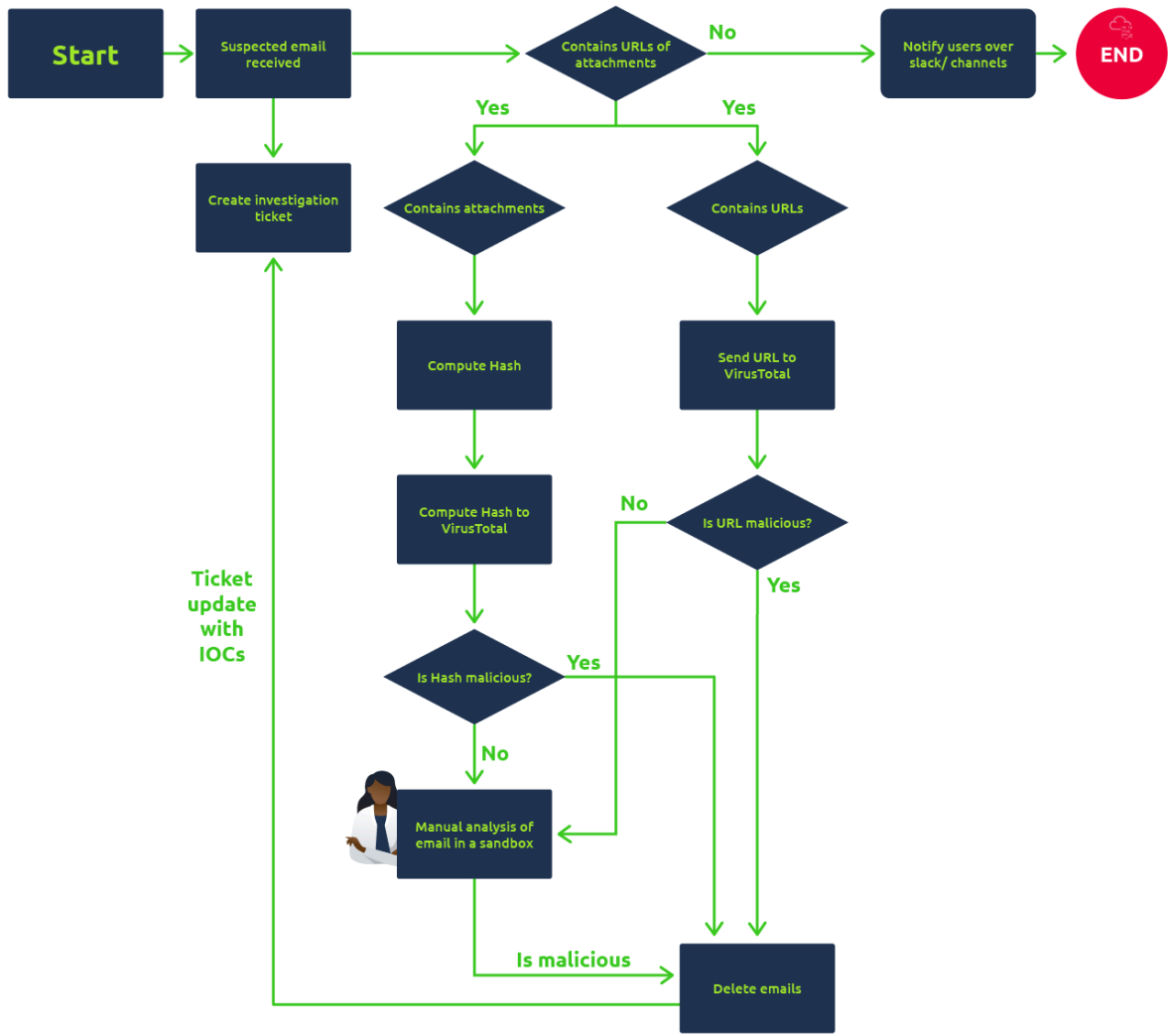
SOC (Security Operations Center) analistleri, kurum içinde sürekli tekrarlayan (recurring) spesifik alarm kategorileri için Playbook'lar inşa ederler. Olay müdahale (Incident Response) süreçlerini otomatize eden bu mimariyi anlamak için endüstride en sık karşılaşılan iki temel senaryoyu inceleyeceğiz: Oltalama (Phishing) ve Zafiyet Yamama (CVE Patching).

1. Phishing (Oltalama) Playbook'u ve Mantıksal Akışı

Oltalama saldırıları (Phishing attacks), kurum ağlarına sızmak için kullanılan en yaygın **Initial Access (İlk Erişim)** vektörüdür. Bir SOC analisti için şüpheli e-postaları manuel olarak incelemek; ekteki (attachment) dosyaların zararlı analizini yapmak, e-posta içindeki URL'leri ayıklamak ve bu **IoC (Indicator of Compromise - Uzlaşma Göstergesi)** verilerini CTI (Cyber Threat Intelligence - Siber Tehdit İstihbaratı) platformlarında doğrulamak son derece zaman alıcıdır.

SOAR çözümleri, analistler diğer kritik vakalarla ilgilenirken bu rutin görevleri arka planda bir Playbook aracılığıyla icra eder. Eğer e-postanın zararlı olduğu (True Positive) doğrulanırsa, iyileştirme/karantina (remediation) süreçleri otomatik olarak başlatılır.

Bir Phishing Playbook'unun mantığı, aslında kıdemli bir SOC analistin (Tier 3), yeni başlayan bir analiste (Tier 1) olay müdahale adımlarını "Eğer bu olursa, şunu yap; olmazsa bunu yap" (If-Else koşulları) şeklinde bir akış şemasıyla anlatmasıdır.



Sürecin teknik adımları şu şekildedir:

1. **Tetikleyici (Trigger):** Kullanıcıdan veya e-posta güvenlik ağ geçidinden (Secure Email Gateway) "Şüpheli e-posta alındı" alarmı SOAR'a düşer.
2. **Kayıt ve Takip:** SOAR, otomatik olarak vaka yönetim sisteminde (Örn: Jira, TheHive) bir bilet (ticket) oluşturur.
3. **Ayrıştırma (Parsing) ve Karar Ağacı:** E-posta içeriği taranır. Sistem şu soruyu sorar: *E-posta bir URL veya dosya eki içeriyor mu?*
 - Hayır ise: Yalnızca e-postayı raporlayan kullanıcıya bir bilgilendirme maili atılır ve vaka kapatılır.
 - Evet ise: URL ve dosya ekleri (hashes) çıkartılır (extraction).
4. **Zenginleştirme (Enrichment):** Çıkartılan IoC'ler VirusTotal, URLScan gibi istihbarat servislerine API üzerinden gönderilir.
5. **Müdahale (Response):** İstihbarat sonucu zararlıysa, SOAR e-posta sunucusuna (Örn: Exchange) komut göndererek maili tüm kullanıcıların posta kutularından kalıcı olarak siler (Hard Delete) ve gönderici adresi engellenir.

```
# Örnek bir SOAR Phishing Playbook Koşul Bloğu (Mantıksal Kavrama)
condition_node_1:
  if: "email.has_attachment == true OR email.has_url == true"
  then:
```



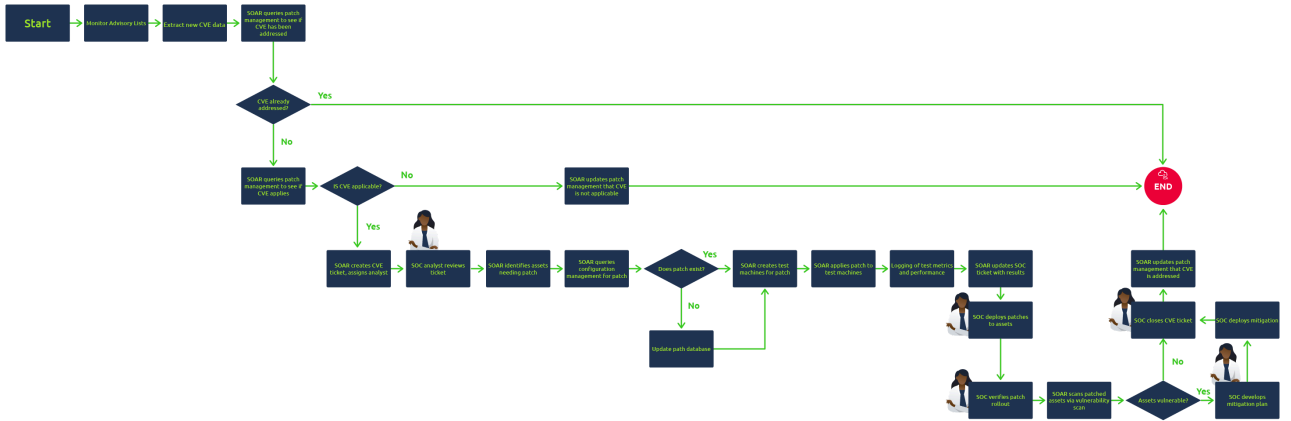
```
action: "extract_indicators"
next_step: "threat_intel_lookup"
else:
action: "notify_user"
message: "Analiz edildi, zararlı unsur bulunmadı."
next_step: "close_ticket_false_positive"
```

Yukarıdaki YAML kesiti, SOAR'ın arka planda olayları nasıl bir mantıksal süzgeçten geçirdiğini gösterir. Bu yapılandırılmış kod sayesinde sistem, binlerce şüpheli e-postayı insan hatası olmadan saniyeler içinde tasnif eder ve yanlış pozitifleri (False Positive) analistin önüne düşmeden eler.

2. CVE Patching (Zafiyet Yamama) Playbook'u ve Risk Yönetimi

CVE (Common Vulnerabilities and Exposures), kamuya açıklanmış ve standart bir numaralandırma sistemiyle etiketlenmiş güvenlik zafiyetleridir. Zafiyet yönetimi (Vulnerability Management) kapsamında SOC ekipleri, sürekli yayınlanan yeni CVE'leri takip etmek, ağlarındaki sistemlerin (asset) bu zafiyetten etkilenip etkilenmediğini doğrulamak ve eğer etkileniyorsa yama (patch) uygulamak zorundadır.

Zafiyetlerin her gün yayınlanması, bu sürecin manuel yönetimini imkansız kılar. Biriken zafiyetler (backlog) ve uygulanamayan yamalar, kurum ortamını dış saldırılara karşı savunmasız bırakır. SOAR, zafiyet yamama sürecini uçtan uca yönetmek için özel Playbook'lar kullanır.



Bir CVE Patching Playbook'unun mimarisi, riskin tespitinden yamanın prodüksiyon ortamına alınmasına kadar olan süreci kapsar:

- İstihbarat Toplama (Ingestion):** Ulusal Zafiyet Veritabanı'ndan (NVD) yeni bir CVE yayını otomatik olarak çekilir.
- Risk Eşiği Değerlendirmesi (Risk Threshold Assessment):** Zafiyetin **CVSS (Common Vulnerability Scoring System)** puanı analiz edilir. Sadece belirli bir risk seviyesinin (Örn: High veya Critical) üzerindeki CVE'ler için otomatik süreç başlatılır.
- Varlık Taraması:** SOAR, kurumun CMDB (Configuration Management Database) sistemini sorgulayarak zafiyetten etkilenen sunucu veya uygulamaları tespit eder.

4. **Biletleme:** IT veya Sistem Yönetimi ekipleri için detaylı bir "Yama Uygulama (Patching)" bileti oluşturulur.
5. **Test Aşaması:** *Bu aşama kritik öneme sahiptir.* Yama, doğrudan canlı (production) ortama sürülmez. Önce izole bir test ortamında uygulanarak sistemin stabil çalışıp çalışmadığı (uyumluluk) test edilir.
6. **Dağıtım (Deployment):** Test başarılıysa, yama canlı ortama basılır.

Analistin Rolü (Human-in-the-Loop Mantığı)

Yukarıdaki her iki Playbook şemasında da süreçlerin büyük çoğunluğu otomatize edilmiş olsa da, iş akışının kritik karar noktalarında bir **SOC Analistinin (Human-in-the-Loop)** bulunduğu görülür.

Neden SOAR her şeyi tek başına yapmıyor? Çünkü SOAR bir kurallar bütünüdür, kurumun iş dinamiklerini ve ticari bağlamını (business context) bilemez. Örneğin; CVE yamama sürecinde, kritik bir üretim sunucusunun anında yeniden başlatılması milyonlarca dolarlık zarara yol açabilir. SOAR riski tespit eder, bileti açar, yamayı hazırlar ancak yamanın "ne zaman" uygulanacağı veya spesifik bir iş riskinin kabul edilip edilmeyeceği (Risk Acceptance) kararını bir SOC analistinin vizyonuna bırakır. SOAR analistlerin yerini almaz; onları tekrarlayan görevlerin yükünden (Alert Fatigue) kurtararak, kritik doğrulama ve stratejik karar alma süreçlerine odaklanmalarını sağlar.